

PRUEBA TÉCNICA · CIBERSEGURIDAD

Plan de Sprints

Programa de seguridad · Sprints 0-5

PREPARADO POR	Lady Marcela Romero Rivero
ROL	Líder de Ciberseguridad
CLIENTE	Simon Movilidad
ESCENARIO	FleetSec S.A.S. — Telemetría de flotas
FECHA	25 de agosto de 2026
VERSIÓN	1.0

CONFIDENCIAL — Exclusivo para Simon Movilidad

Tabla de contenido

Sprint 0 — Fundaciones y descubrimiento (semana 0)

Sprint 1 — Pipeline DevSecOps (Entregable 01)

Sprint 2 — VAPT y remediación (Entregable 02)

Sprint 3 — Hardening de infraestructura AWS (Entregable 03)

Sprint 4 — Detección y respuesta a incidentes (Entregable 04)

Sprint 5 — Documentación, evidencia y sustentación (Entregable 05 + video)

Roadmap posterior (fuera del alcance de la prueba)

Cada sprint = 1 semana. Cada uno declara objetivos, entregables, controles DevSecOps y **Definition of Done (DoD)**. Mapea 1:1 con los entregables de la prueba.

Sprint 0 — Fundaciones y descubrimiento (semana 0)

- **Objetivos:** establecer la base del ISMS, inventario de activos, repositorio y tooling; contener la alerta de credenciales AWS comprometidas (contexto del escenario).
- **Alcance:** setup del repo, Conventional Commits, pre-commit hooks, definición de scope ISMS (ISO 27001 cl. 4-6), inventario de datos personales (Ley 1581).
- **Entregables:** repo con `.pre-commit-config.yaml`, CODEOWNERS, `.gitignore`, scope statement, política de seguridad borrador.
- **Controles DevSecOps:** gitleaks pre-commit; rotación de emergencia de las credenciales AWS alertadas.
- **DoD:** repo inicializado; hooks activos; secretos comprometidos rotados y documentados; commit inicial atómico.

Sprint 1 — Pipeline DevSecOps (Entregable 01)

- **Objetivos:** pipeline de seguridad completo en GitHub Actions, ≤ 15 min.
- **Alcance:** SAST (Semgrep + 4 reglas propias), SCA (Trivy), SBOM CycloneDX, DAST autenticado (ZAP), escaneo de imagen, IaC (Checkov), secretos (Gitleaks), break-glass.
- **Entregables:** `.github/workflows/devsecops.yml`, `break-glass.yml`, `semgrep/`, OpenAPI spec.
- **Controles DevSecOps:** quality gates (0 CRITICAL/HIGH en prod con supresión documentada; CVSS $\geq 8/\geq 9$; CRITICAL en imagen; HIGH/CRITICAL en DAST).
- **DoD:** todos los stages activos y verdes; SBOM generado en cada build; pipeline < 15 min (fan-out + caché); break-glass con 2 aprobadores + issue de auditoría.

Sprint 2 — VAPT y remediación (Entregable 02)

- **Objetivos:** demostrar y remediar las 10 clases de vulnerabilidad.
- **Alcance:** app propia con 10 CWE; PoC por hallazgo; fix en código; informe VAPT.
- **Entregables:** `app/` (vuln + secure), `app/tests/` (20 tests), `vapt/vapt-report.md` + `.pdf`.
- **Controles DevSecOps:** cada fix con test doble (payload malicioso $\rightarrow$ rechazo; flujo legítimo $\rightarrow$ OK); V-10 a Secrets Manager; V-08 sanitizador PII.
- **DoD:** $\geq 8/10$ remediados (logrado 10/10); CVSS con vector completo; mapa de superficie; informe PDF; 20/20 tests verdes.

Sprint 3 — Hardening de infraestructura AWS (Entregable 03)

- **Objetivos:** baseline segura como IaC.
- **Alcance:** IAM mínimo, S3 + Object Lock, VPC 3 capas, RDS Multi-AZ CMK, KMS, Secrets Manager, CloudTrail, Config, GuardDuty, Security Hub, WAFv2.

- **Entregables:** `terraform/modules/security-baseline` , `terraform/environments/prod` , `checkov/` , tabla de cumplimiento.
- **Controles DevSecOps:** `terraform validate` ; Checkov hard-gate (bloquea SG 0.0.0.0/0 en 22/3389); ≥ 10 controles mapeados a CIS/ISO/Ley 1581.
- **DoD:** HCL válido; Checkov 251 passed / 0 failed / 12 skips documentados; tabla de cumplimiento ≥ 10 controles con PASS/FAIL/N/A.

Sprint 4 — Detección y respuesta a incidentes (Entregable 04)

- **Objetivos:** capacidad de detección y un playbook IR ejecutable.
- **Alcance:** IOCs enriquecidos, Threat Intel Set GuardDuty, 4 reglas Sigma, playbook con CLI, MITRE ATT&CK, RCA, resumen CEO, plan P1/P2/P3.
- **Entregables:** `detection/sigma/` , `detection/threat-intel/` , `detection/playbooks/ir-playbook.md` .
- **Controles DevSecOps:** reglas Sigma validadas (pysigma); Threat Intel Set vía Terraform; alertas HIGH+ a SNS.
- **DoD:** IOCs enriquecidos; 4 reglas Sigma válidas; playbook con CLI exacto; ≥ 6 técnicas ATT&CK; resumen CEO ≤ 1 pág.; notificación SIC (Ley 1581) contemplada.

Sprint 5 — Documentación, evidencia y sustentación (Entregable 05 + video)

- **Objetivos:** cerrar documentación y grabar la sustentación.
- **Alcance:** README, ADRs, diagramas as-is/to-be, Reporte de IA, Desafíos y Próximos Pasos; video ≤ 10 min con cámara.
- **Entregables:** `README.md` , `docs/adr/*` , `docs/diagrams/architecture.md` , `docs/ai-report.md` , video (YouTube no listado).
- **Controles DevSecOps:** verificación final (linters, tests, parsers) como puerta de release.
- **DoD:** README completo con enlace al video; ADRs de decisiones clave; diagrama de arquitectura; Reporte de IA (con alucinación admitida); commits Conventional Commits.

Roadmap posterior (fuera del alcance de la prueba)

- Sprint 6: certificación ISO 27001 (SoA, análisis de riesgos ISO 27005, auditoría interna ISO 19011).
- Sprint 7: SOC / SIEM 24x7, threat hunting continuo, purple team.
- Sprint 8: federación OIDC (eliminar llaves estáticas), DNS Firewall, egress firewall.